



AXIOMATIC LAB REPORT

MAXIMIZING PRECISION & INNOVATION

Get your time back, visit axiomaticlab.com

EU AI Act

Compliance Readiness Guide

2026

Prepared By:
Daniel Marques

This a complete, step by step guide, broken down into 4 easy-to-follow sections, to ensure your AI deployment is fully compliant with the EU AI Act and other relevant regulation. By following the steps in this report, you will have a fully compliant AI implementation, including:

- A clear understanding of the AI tools your company is using, and how they are being used
- Clear understanding of the social and regulatory risks and impacts present in your AI implementation
- Clearly assigned goals and responsibilities for AI implementations and the outcomes they generate
- A clear and easy to follow training guide, designed specifically for your organization
- And above all, according to the Q2 KPMG AI report, you will significantly increase (5x) the probability that your AI investment has a real business ROI

You can find the Official EU AI Act Regulation here <https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer>

Table of Contents

Phase 1 - Deep Dive.....3

 Step 1.1: The AI Inventory & Opportunity Pipeline.....3

 Step 1.2: Risk Triage & Matrix Template.....4

 Bonus Industry Specific Questions.....8

Phase 2 - The People Layer (Article 4).....12

 Step 2.1: Assign the "Human-in-the-Loop".....12

 Step 2.2: Execute Role-Based Training.....12

 Sample One-Page training guide for Organizations using only Low-Risk AI.....13

Phase 3: The Rights Assessment (Article 27 FRIA)17

 Step 3.1: Conduct the FRIA.....18

 Step 3.2: Submit to Authority.....18

Phase 4: Operational Infrastructure (Article 26).....25

 Step 4.1: Technical Integration for Logging.....25

 Step 4.2: Worker/Internal Notification.....25

BONUS: Training Module Guide.....26

 Company-Wide AI Literacy & Training Guide.....26

 Tier 1: General Workforce (Foundation Level).....26

 Tier 2: High-Risk Operators (The "Human-in-the-Loop").....26

 Tier 3: Executive & Compliance (Governance Level).....26

Phase 1 - Deep Dive

The first step in your AI deployment strategy is to understand what are the current official and unofficial uses of AI across your organization. As part of this exercise, we will also be looking for any potential additional use cases that can be beneficial for the organization. This is not a do it and forget it regulation, as you add new AI tools and systems, you will have to go through similar steps to identify the risk factor and appropriate steps to take for compliance, so be sure to save this report for future reference.

With the **August 2, 2026** transparency laws now live, customer chatbots must be labeled immediately. However, you have until **December 2, 2027** to finalize architectural logging for standalone high-risk systems, meaning your procurement team is in a critical engineering window right now.

Moving Forward: To transition this guide into an active operational strategy for your business, explore our weekly newsletter breakdowns, stream our latest podcast episodes, or engage our team for custom corporate consulting at <https://axiomaticlab.com/>.

Step 1.1: The AI Inventory & Opportunity Pipeline

- Create a centralized registry tracking two distinct tracks: Active/Shadow AI (for risk triage) and the AI Opportunity Pipeline (for future deployment).
- **Action:** Survey department heads for existing tools and friction points in their daily operations that could be solved by automation or intelligence.

Below is an example email to send out to all department heads and other relevant management in your organization. It is important that this is seen by any staff member that has the authority to procure and on-board software for your organization, including, the use of AI tools purchased by employees personally that are used for business activities.

* Tip: make sure employees are not using personal accounts from AI model providers and other tools, as the messages sent through consumer accounts are generally used for training data, potentially exposing your firm to not only a breach of EU AI Act, but of GDPR rules as well. This is one of the most common use case of "Shadow AI" and can be hard to catch. It is helpful to ensure that managers remain actively vigilant and monitor staff periodically to ensure they are not using unauthorized AI tools.

Example Email:

Subject: Internal Audit & Innovation: Mapping Our AI Footprint and Future Needs

Team,

To ensure compliance with the upcoming EU AI Act, we are building a centralized AI Inventory. We need to log every software tool that uses automated decision-making, predictive analytics, or generative content.

At the same time, we want to use this opportunity to uncover new ways to support your team. If there are manual, repetitive tasks slowing you down, we want to know so we can proactively explore compliant AI solutions for you.

Please reply with your inputs for both sections below by [Date].

Part 1: Current AI Footprint (Active & Testing)

Please list any tools your department currently uses, or is testing, that use automated or intelligent features (including features inside your current HR, sales, or data software, not just standalone AI apps). Make sure to include both tools the company provides, as well as, any other personal AI tools you and your staff might be using.

For each current tool, please provide:

- 1. Software Name & Vendor: (e.g., Workday, ChatGPT, custom Python script)
- 2. Exact Use Case: (e.g., "Screening resumes," "Writing marketing copy")
- 3. Data Inputs: (e.g., "Employee performance metrics," "Customer emails")
- 4. User Access: Who in your department uses this tool?

Part 2: Future AI Opportunities (Proactive Innovation)

Think about your team's current bottlenecks. Where are you spending too much time on manual work?

- 1. The Problem: Describe a repetitive, manual task you wish could be automated or enhanced by AI (e.g., "Summarizing 50-page vendor contracts," "Manually categorizing support tickets").
- 2. The Ideal Outcome: What would the perfect tool do for your team?
- 3. Estimated Time Saved: How many hours per week does your team spend on this manual task?

Step 1.2: Risk Triage & Matrix Template

- Classify each tool in your inventory against Annex III of the AI Act.
- Is it High Risk? Does it impact recruitment, employee management, credit scoring, insurance, education, or critical infrastructure?

Decision: If YES, proceed to Phase 2. If NO (e.g., a chatbot for customer service), you only need to satisfy transparency rules (labeling) and Article 4 (AI Literacy/Basic Training).

- **Output:** Use the Example table and the questionnaire below to create a full list of all current and potential AI Uses Cases and their Risk Category



Here is an example of how to you can structure and organize your findings.

Tool Name	Department	Core Function / Use Case	Risk Category	Next Compliance Step
Example: ResumeScanner Pro	HR	Filters inbound job applications based on keywords.	High Risk (Annex III: Employment)	Route to Phase 2 (Human-in-the-Loop & Training).
Example: SupportBot v2	Customer Success	Answers basic FAQ queries on our public website.	Low/Minimal Risk	Implement Article 52 Transparency (Clear label stating: "You are talking to an AI").
Example: DeskMood AI	HR / Operations	Analyzes employee webcam expressions to gauge workplace stress.	PROHIBITED (Article 5)	STOP USE IMMEDIATELY. Decommission tool.

Here is a list of questions that you can follow to help you determine the risk level of each AI use case identified:

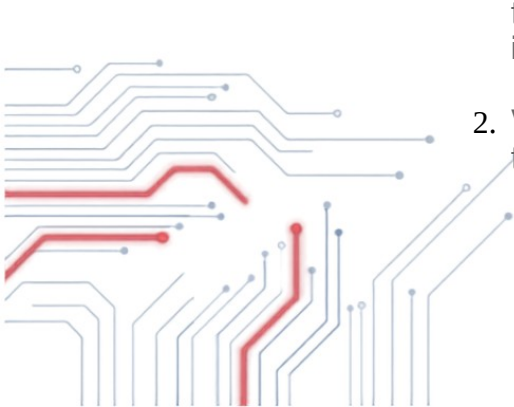
Prohibited AI - Stop using immediately

Reference: Article 5

If you answer YES to any of these, the tool is ILLEGAL. Do not deploy.

Questions

- Subliminal Manipulation:** Does the AI use subliminal techniques or manipulative tactics to distort behavior and impair informed decision-making?
- Vulnerability Exploitation:** Does it exploit vulnerabilities related to age, disability, or social/economic situation to cause harm?



3. **Social Scoring:** Does it evaluate or classify natural persons over time based on social behavior or personality traits, leading to detrimental treatment in unrelated contexts?
4. **Real-Time Biometrics:** Is it used for "real-time" remote biometric identification in publicly accessible spaces for law enforcement purposes? (Unless strictly authorized by judicial order).
5. **Predictive Policing:** Does it assess the risk of an individual committing a crime based *solely* on profiling or personality traits?
6. **Emotion Recognition (Restricted):** Is the system used to infer emotions of a natural person in the areas of **workplace** or **education** institutions?
7. **Untargeted Scraping:** Does the system expand facial recognition databases by untargeted scraping of facial images from the internet or CCTV footage?

IF YES: STOP IMMEDIATELY

- **Risk Category: Unacceptable Risk (Prohibited).**
- **Action:** Decommission the tool. Cancel the contract. Do not proceed.
- **IF NO:** Proceed to "High-Risk AI" Section.

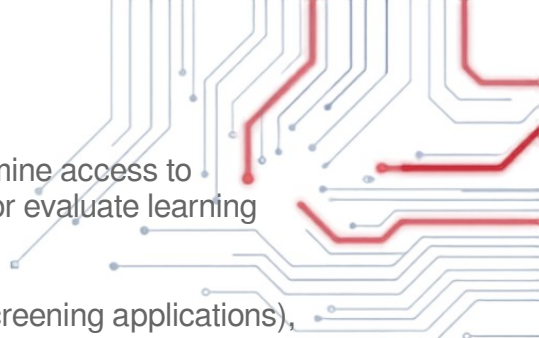
High-Risk AI - Heavy Regulatory Requirements

Reference: Article 6 & Annex III

If you answer YES to any of these, you face the heaviest compliance burden.

Questions

1. **Safety Component:** Is the AI a safety component of a product regulated under EU harmonization legislation (e.g., medical devices, toys, cars, machinery, elevators)?
2. **Biometrics (non-prohibited):** Is it used for remote biometric identification (post-remote), biometric categorization (e.g., race/religion inference), or emotion recognition (outside work/school)?
3. **Critical Infrastructure:** Is it a safety component in the management of road traffic, water, gas, heating, or electricity supply?

- 
4. **Education & Training:** Is it used to determine access to education, assign students to institutions, or evaluate learning outcomes/testing?
 5. **Employment:** Is it used for recruitment (screening applications), making promotion/termination decisions, or monitoring employee performance?
 6. **Essential Services:** Is it used to evaluate eligibility for public benefits/services, or for **credit scoring/creditworthiness** evaluation (except for detecting financial fraud)?
 7. **Law Enforcement:** Is it used by law enforcement for polygraphs, evaluating evidence reliability, or profiling (non-prohibited types)?
 8. **Migration & Borders:** Is it used for polygraphs, assessing security risks of travelers, or examining travel documents?
 9. **Justice & Democracy:** Is it used to assist judges in interpreting the law or influencing the outcome of an election/voting behavior?

IF YES: INITIATE COMPLIANCE

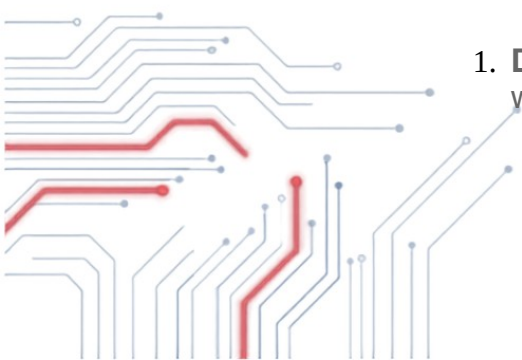
- **Risk Category: High-Risk AI.**
- **Action:** You are a **Deployer** under Article 26.
 - Implement Human Oversight (Art. 14).
 - Monitor logs and operations (Art. 26).
 - Conduct a Fundamental Rights Impact Assessment (FRIA) (Art. 27).
 - Inform workers/unions (Art. 26).
- **IF NO:** Proceed to "Limited Risk AI" Section.

Limited Risk AI - Labeling and Transparency

Reference: Article 50 (Transparency Obligations)

If you answer YES, your primary duty is disclosure.

Questions

- 
1. **Direct Interaction:** Is the system intended to interact directly with natural persons (e.g., Chatbots, Customer Service AI)?

2. **Generative Content:** Does the system generate synthetic audio, image, video, or text content (e.g., ChatGPT, MidJourney)?
3. **Deep Fakes:** Does it generate deep fakes (manipulated image/audio resembling existing persons/places)?
4. **Emotion Recognition (General):** Is it an emotion recognition system (permitted use cases only, outside work/school)?

IF YES: TRANSPARENCY REQUIRED

- **Risk Category: Limited Risk (Transparency).**
- **Action:**
 - **Chatbots:** You must inform the user they are interacting with a machine.
 - **GenAI/Deep Fakes:** You must mark the output as artificially generated/manipulated (machine-readable watermarking).
 - **Emotion Rec:** You must inform the natural person exposed to the system.
- **IF NO:** Proceed to "Minimal Risk AI" Section.

Minimal Risk - No Legal Obligations

Reference: Article 69 (Voluntary Codes)

Everything else falls here.

Questions

- Does the tool perform tasks *not* covered in Gates 1, 2, or 3?
- *Examples: Spam filters, AI-enabled video games, inventory management predictors, document search tools (non-legal), maintenance scheduling.*

IF YOU ARE HERE

- **Risk Category: Minimal Risk.**
- **Action:** No new legal obligations under the AI Act.

- **Recommendation:** Adhere to general GDPR principles and consider voluntary codes of conduct.

Bonus Industry Specific Questions

If your company operates in a high risk industry such as the ones mentioned below, make sure to include the following questions when going through the "High Risk" portion of this questionnaire

Reference: Article 6 & Annex III

Use the specific track below that matches your industry. If you answer YES to any question in your track, the system is High-Risk.

Track A: Healthcare & Life Sciences

1. **Medical Device Regulation (MDR/IVDR):** Is the AI a safety component of a medical device (or a device itself) that requires a third-party conformity assessment under the EU MDR or IVDR?
2. **Emergency Triage:** Is the system used to dispatch emergency services (ambulance, fire) or to prioritize/triage patients in emergency healthcare settings?
 - *Note: Administrative tools (e.g., appointment scheduling, bed management) are generally NOT High-Risk.*

Track B: Finance & Insurance

1. **Creditworthiness:** Is the system used to evaluate the credit score or creditworthiness of natural persons?
 - *Exemption:* If the system is used **exclusively** for detecting financial fraud, AML, etc., answer **NO**.
1. **Life & Health Insurance:** Is the system used for risk assessment, access-to-care decision, or pricing in relation to life and health insurance products?
 - *Note: Investment algorithms and general property insurance are typically NOT High-Risk under Annex III.*

Track C: Education & HR

1. **Access & Admissions:** Is the system used to determine access to education (e.g., processing applications) or assigning students to specific educational levels/tracks?
2. **Student Evaluation:** Is the system used to assess learning outcomes (grading) or proctor tests?
3. **Recruitment:** Is it used to place targeted job ads, screen applications, or shortlist candidates?
4. **Workplace Management:** Is it used to make decisions on promotion, termination, or task allocation based on individual behavior/performance monitoring?

Track D: Critical Infrastructure & Public Services

1. **Critical Utilities:** Is the AI a safety component in the supply of water, gas, heating, or electricity?
2. **Public Benefits:** Is it used to evaluate eligibility for public assistance benefits and services?

Track E: GovTech, Security & Law Enforcement Contractors

Applicable if you supply technology to police, border control, or migration authorities.

1. **Risk Assessment (Crime):** Is the system used to assess the risk of a natural person becoming a victim of a crime or causing a crime (polygraphs/profiling)?
2. **Deepfake Detection:** Is the system used by law enforcement to detect deepfakes or verify the authenticity of travel documents?
3. **Evidence Reliability:** Is it used to evaluate the reliability of evidence in criminal proceedings?
4. **Migration & Asylum:** Is the system used to examine applications for asylum, visa, or residence permits, or to assess the security risk of travelers?

Track F: LegalTech & Public Administration

Applicable to the Judiciary and Democratic institutions.

1. **Judicial Interpretation:** Is the system used to assist a judicial authority in researching and interpreting facts or the law and applying the law to a concrete set of facts?

2. **Democratic Influence:** Is the system used to influence the outcome of an election or referendum, or the voting behavior of natural persons?
- *Note: This does not include purely administrative tools, only those that influence behavior.*

Track G: Industrial Manufacturing & Transport (The "Safety Component" Rule)

Applicable to Automotive, Aviation, Machinery, and Heavy Industry.

This is the broadest "hidden" category. If your AI is a **Safety Component** of a regulated product, it is automatically High-Risk.

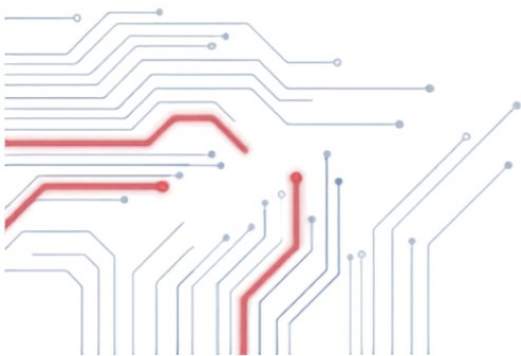
- **Road Traffic Management:** Is the AI intended to be used for the management and operation of road traffic (e.g., smart traffic lights, autonomous traffic flow control)?
- **Regulated Product Safety:** Is the AI a safety component in a product covered by EU Harmonization legislation? Specifically:
 - **Machinery:** (Robots, industrial lines).
 - **Toys:** (AI-enabled smart toys).
 - **Lifts/Elevators:** (Smart dispatch systems).
 - **Explosive Atmospheres (ATEX):** (Safety sensors).
 - **Radio Equipment:** (Network management).
 - **Pressure Equipment & Gas Appliances.**
 - **Civil Aviation, Cars, Marine Equipment, & Rail.**

If you answer **NO** to all questions in Tracks A (Healthcare), B (Finance), C (Education/HR), D (Infra), E (GovTech), F (Legal), and G (Manufacturing), your system is likely **NOT High-Risk**.

Next Steps Checklist (If YES to any above)

If you triggered a "YES" in any of these High-Risk tracks, you must immediately verify the following before deployment:

- Confirm if your vendor (Provider) has placed the **CE Mark** on the system.
- Request the **Instructions for Use** (IFU) and Technical Documentation from the vendor.



Phase 2 - The People Layer (Article 4)

You cannot deploy high-risk AI until your staff is competent to use it. This step is especially crucial if your organization has identified high-risk cases. If your organization does not have any high-risk use cases, this phase is going to be limited to minimal AI training course of measurable proportion to the size of your business and risk level, however, recent reports from KPMG suggested that having clear lines of responsibility for AI outcomes and cost can massively (3-5x) increase your likelihood of seeing a positive ROI on your organization's AI investments. You can find a bonus sample 1-page training for Small and Medium size businesses looking to adopt simple and low-risk AI tools like AI chatbots and AI wrappers, you can copy and paste this training or customized as needed for your organization.

Step 2.1: Assign the "Human-in-the-Loop"

Identify specific individuals responsible for overseeing the AI's output, these individuals will serve as a first layer of accountability for the continuous monitoring and outputs of each AI tool used. If you want to go a step further, we recommend aligning AI output responsibilities with the organizations leadership structure rather than creating a separate hierarchal structure for AI outcomes and decisions. This will likely require training of senior/management staff, as well as, possible adjustments to current leadership/operational structures and chains-of-command, that better align with the needs of a successful AI strategy.

- Key Mechanisms to Build:
 - The "Kill Switch" Authority: Who within the company has the specific training and legal authority to oversee and override or shut down the AI system if it misbehaves?
 - Redress & Appeals: What internal complaint channel or process will be available for customers/citizens to appeal an automated decision?
 - Data & Bias Audits: How often will technical teams run tests to check the AI output for drifting accuracy or emerging biases?

Requirement: These individuals must have the authority and competence to override the AI or stop the system. Making it crucial for that the parties ultimately responsible for AI outputs be organizational leaders that have the authority to take decisive action. It is important to make sure that existing leadership is adequately trained in the AI tool being used, as well as, the expected outputs to ensure they are capable of catching errors and discrepancies as they appear.

- **Output 1:** AI responsibility hierarchy/chain-of-command
- **Output 2:** Develop necessary key mechanisms, including regular Data/Bias Audits, for each tool, as needed. (ex. if a person has "Kill Switch" authority over a tool, make sure tool and user have adequate access and ability to switch off the tool quickly and easily)

Step 2.2: Execute Role-Based Training

Launch the training curriculum (detailed in Part 2 below) for all affected staff. If you have assigned human responsibilities above, it is largely recommended that these roles/functions have specific

trainings on the AI use-cases they are tasked with supervising, this is especially important for high-risk applications. You can follow our help training guide in the appendix for step-by-step instructions on how to create the full training materials and process for your organization.

- **Output:** Create Training Materials and a Training Log documenting who was trained, when, and on what syllabus. This is a legally required compliance document. (See example below)

Sample One-Page training guide for Organizations using only Low-Risk AI

Below is a clean, practical, one-page Internal AI Policy Template tailored for Small and Medium Enterprises (SMEs). It complies with the baseline AI Literacy requirements under Article 4 of the EU AI Act. It covers both primary standalone AI chatbots (like Claude, ChatGPT) and AI productivity wrappers/notetakers (like Granola, Scribble, etc.).

[Company Name] — Internal AI Usage & Literacy Policy

1. Purpose & Scope

This policy ensures our team uses Artificial Intelligence (AI) tools safely, productively, and in compliance with global standards (including the EU AI Act). It applies to all employees, contractors, and external partners operating under our authority.

It covers two main categories of tools:

- Standalone AI Chatbots: Tools where you directly prompt an AI for text, code, or media generation (e.g., ChatGPT, Claude, Gemini).
- AI Productivity Wrappers: Tools built on top of AI models that automatically summarize meetings, record audio, capture notes, or streamline workflows (e.g., Granola, Scribble, Otter.ai).

2. Core Pillars of AI Literacy (Our Operational Rules)

To satisfy our legal duty of AI literacy, every team member must understand and apply these three core principles:

- AI Outputs are **Predictions**, Not Facts: AI models generate text based on statistical patterns, meaning they can confidently state falsehoods ("hallucinations"). Never rely on AI data without verifying it.
- Human-in-the-Loop Requirement: A human must manually review, fact-check, and edit any AI-generated output before it is shared externally, published, or used to make operational decisions.
- Bias and Awareness: Be aware that AI outputs can inherit biases from their training data. Evaluate AI suggestions critically.

3. Data Privacy & Confidentiality (Crucial)

Protecting our proprietary data and client privacy is our highest priority.

- **No Sensitive Ingestion:** You are strictly forbidden from typing, pasting, or uploading proprietary business code, financial statements, trade secrets, HR records, or customer personal data into any public AI chatbot.
- **Meeting Recording & Wrappers:** Before activating AI meeting wrappers (like Granola or Scribble) that record, transcribe, or summarize audio, you must obtain explicit verbal consent from all participants on the call.
- **System Settings:** Where available, toggle "Data Training Opt-Out" settings to ensure the AI provider does not use our prompts or notes to train future public models.

4. Permitted vs. Prohibited Tool Use

Approved / Permitted Use Cases	Prohibited / High-Risk Use Cases
Writing initial drafts for marketing copy, emails, or blog posts.	Evaluating employee performance or screening job applications using AI.
Brainstorming ideas, outlines, and structuring presentations.	Processing sensitive health, medical, biometric, or banking data.
Summarizing long, non-confidential public articles or open reports.	Allowing an AI tool to automatically publish content without human review.
Generating basic Excel formulas, scripts, or boiler-plate templates.	Uploading third-party intellectual property or copyrighted materials.

5. Compliance & Reporting

- **Approved Tool List:** Only use AI tools officially approved by [Management / IT Team]. Do not sign up for unvetted third-party AI extensions or software with company emails, and do not use personal third-party AIs for any business related work, you must use internal tools only for work-related tasks.
- **Mistake Reporting:** If you realize confidential data was accidentally pasted into an AI system, report it immediately to [Contact Person/Role] so we can attempt a data deletion request.

How to use this template to fulfill your Article 4 requirement:

1. Fill in the blanks: Replace the bracketed text with your company's specifics.
2. Distribute & Log: Email this document to all staff. Ask them to reply a simple acknowledgment confirmation (or sign a digital log) and to complete the training (see below).
3. Keep the Record: File those confirmations away. If an auditor ever asks for your "Article 4 AI literacy compliance," showing this policy and your team signature log serves as your evidence of taking proportional baseline measures.
Distribution/login tip: To create a clean paper trail for auditors, paste these

questions into a free form builder (like Google Forms or Microsoft Forms). Set the form to collect employee names and email addresses. You can then export the results to a spreadsheet to instantly prove 100% team completion and understanding. Keeping a log of training completions is mandatory.

Sample Quiz:

[Company Name] — AI Policy & Literacy Assessment

Instructions: Please select the best answer for each question based on our Internal AI Usage Policy.

1. You are using an AI chatbot to draft an email to a client. The AI includes a specific statistic about market trends. What must you do before sending the email?

- A. Send it immediately because AI tools are trained on verified global data.
- **B. Manually verify the statistic against a trusted source and edit the text before sending.**
- C. CC your manager so they can fact-check it after it is sent.

2. You want to use an AI productivity tool (like Granola or Scribble) to record and summarize an upcoming project meeting. What is required before you turn it on?

- A. Nothing, as long as it is an internal company meeting.
- B. You only need permission if external clients are on the call.
- **C. You must obtain explicit verbal consent from all participants on the call before activating it.**

3. Which of the following data types is PERMITTED to be typed or uploaded into a public standalone AI chatbot?

- A. A client's personal email address and phone number.
- **B. A rough, generic outline for a new marketing campaign structure.**
- C. The company's unreleased Q3 financial performance spreadsheet.

4. An AI tool suggests an incredibly efficient formula for your team spreadsheet. What must you keep in mind regarding "Bias and Awareness"?

- A. AI tools are completely objective and free from human bias.
- **B. AI models can inherit biases from their training data, so you must evaluate their suggestions critically.**
- C. Standard spreadsheets are the only tools completely immune to AI bias.

5. You accidentally paste a block of proprietary code containing sensitive client keys into an unapproved AI chatbot. What should you do?

- A. Keep it quiet and hope the AI company's server automatically deletes it later.
- B. Delete your browser history and log out of the AI account immediately.
- **C. Report it immediately to [Contact Person/Role] so a formal data deletion request can be made.**

Answer Key (For Management Tracking)

1. B — AI outputs are predictions, not facts. Human-in-the-loop review is mandatory before external sharing.
2. C — Explicit verbal consent from all participants is required before recording or transcribing.
3. B — General brainstorming is permitted; sensitive, financial, and personal client data are strictly prohibited.
4. B — Employees must remain aware that AI models can inherit training data biases.
5. C — Immediate reporting is crucial for compliance so the company can attempt to mitigate the data leak.

Distribution Tip

To create a clean paper trail for auditors, paste these questions into a free form builder (like Google Forms or Microsoft Forms). Set the form to collect employee names and email addresses. You can then export the results to a spreadsheet to instantly prove 100% team completion and understanding. Keeping a log of training completions is mandatory.

Phase 3: The Rights Assessment (Article 27 FRIA)

This part is only mandatory for public bodies and private entities providing public services (e.g., banking, insurance, healthcare). To help you understand if this portion of the regulation applies to your organization, please use the following questionnaire:

Article 27 FRIA Applicability Checklist

A business must complete a Fundamental Rights Impact Assessment (FRIA) only if they answer YES to at least one of the four institutional or sectoral categories below.

Category 1: Public Sector Status

- Question 1.1: Is your organization a body governed by public law, a government agency, or a public authority?
- Question 1.2: Is your entity a public body deploying a high-risk AI system listed in Annex III (such as law enforcement, migration, education, or employment tools)?

Category 2: Private Entities Providing Public Services

- Question 2.1: Is your business a private or semi-private entity, but the specific AI tool will be used to provide an essential public service?
- Question 2.2: Does this service include managing state-regulated critical infrastructure like water, gas, electricity, or public transport networks?
- Question 2.3: Does this service involve providing public healthcare or essential social services on behalf of the state?

Category 3: Banking & Credit Institutions

- Question 3.1: Is your business deploying an AI system to assess the creditworthiness of natural persons or to determine their credit score?
- Question 3.2: *Exception Check*: Is this banking AI tool used strictly and exclusively for financial fraud detection? (If yes, answer NO to this question; fraud detection does not trigger a FRIA).

Category 4: Insurance Providers

- Question 4.1: Is your business an insurance undertaking deploying an AI system for risk assessment regarding natural persons?
- Question 4.2: Will this AI system be used to calculate premiums or set pricing for life insurance policies?
- Question 4.3: Will this AI system be used to calculate premiums or set pricing for health insurance policies?

Any **"YES"** in Categories 1, 2, 3, or 4: Article 27 applies. The business is legally a "deployer subject to Article 27" and must conduct a FRIA and notify the national market surveillance authority before going live.

All **"NO"** Answers: Article 27 does not apply. Even if the business is deploying a high-risk AI system (like an AI resume scanner for HR), they are completely exempt from the FRIA requirement if they do not fit these specific sectors. You skip to the 4th and final Phase.

Step 3.1: Conduct the FRIA

Before the tool goes live, complete a Fundamental Rights Impact Assessment, you can find an easy-to-follow template on how to conduct your FRIA below. This is distinct from a GDPR Data Protection Impact Assessment (DPIA) because it focuses on human rights, not just data privacy. To complete a FRI Assessment for your organization, you can follow the step-by-step guide below.

- **Output 1:** Complete List of Risks Against the EU Charter Scores for each AI tool in your catalog
- **Output 2:** Complete List of Human Oversight and Mitigation Protocols for each AI tool
- **Output 3:** Email Notifying the National Market Surveillance Authority

Step 3.2: Submit to Authority

Notify your national market surveillance authority of the FRIA results.

- Note: You do not always need to wait for approval, but you must notify them of the assessment's completion.

The workflow is broken down into a practical, 6-step implementation playbook for a corporate strategy guide.

Step 1: Assemble the Core Assessment Team

A FRIA cannot be completed by IT or legal alone, it requires diverse organizational perspectives.

- Form a cross-functional compliance squad consisting of four key roles:
 - Legal/Compliance Lead: To map outcomes against the EU Charter of Fundamental Rights.
 - Data/AI Product Manager: To explain the system's logic, limitations, and inputs.
 - Risk/Operations Officer: To oversee real-world business workflows.
 - Data Protection Officer (DPO): To link the FRIA with existing GDPR Data Protection Impact Assessments (DPIAs).

Step 2: Define the AI Deployment Context

Legally, Article 27(1)(a) requires a granular description of your internal workflows and intended usage.

- Document the exact parameters of the AI tool within the organization.
- Key Questions to Document:
 - System Details: What is the specific name, version, and provider of the AI tool?
 - The Workflow: What specific internal business process is this AI doing or augmenting and how?
 - Timeline & Cadence: What is the intended deployment start date, and how frequently will the tool run (e.g., real-time automated loops, daily batches)?
 - The Provider's Playbook: Have you reviewed and integrated the official "Instructions for Use" provided by the AI vendor? (*This is a strict legal requirement under Article 27*).

Step 3: Identify Affected Populations & Vulnerable Groups

Article 27(1)(b) requires a clear breakdown of the specific categories of natural persons impacted by the AI.

- Map out both direct and indirect target groups, taking note of power imbalances.
- Key Questions to Document:
 - Primary Targets: Who are the natural persons directly evaluated by the AI (e.g., loan applicants, patients, policyholders)?
 - Vulnerable Demographics: Does the system process data involving children, elderly individuals, minority groups, or employees in a position of economic dependence?
 - Stakeholder Input: Can you safely consult or gather feedback from representatives of these affected communities during the planning phase?

Step 4: Map and Score Risks Against the EU Charter

This is the core of the FRIA. The team must look beyond data privacy and systematically evaluate human rights.

- Assess the likelihood and severity of negative impacts for each relevant fundamental right. Assign a risk score based on the scope, gravity, and irreversibility of potential harms.
- Crucial Rights to Evaluate:
 - Human Dignity (Art. 1): Does the AI reduce an individual to an unyielding mathematical "score" or profile without context?

- Non-Discrimination (Art. 21): Could historical training data introduce algorithmic bias against specific genders, ethnicities, or socioeconomic statuses?
- Consumer/Health Protection (Art. 35/38): Does a health insurance or credit scoring algorithm inadvertently deny critical, life-altering resources?
- Access to Justice & Due Process (Art. 47): Will individuals be blocked from understanding or contesting a negative decision made by the AI?

Step 5: Design Human Oversight and Mitigation Protocols

Article 27(1)(d) demands a detailed plan outlining exactly how humans will supervise the system and handle failures.

- Establish and document technical, organizational, and contractual safeguards and responsibilities (Phase 1-2.)
- Key Mechanisms to Build:
 - The "Kill Switch" Authority: Who within the company has the specific training and legal authority to override or shut down the AI system if it misbehaves?
 - Redress & Appeals: What internal complaint channel or process will be available for customers/citizens to appeal an automated decision?
 - Data & Bias Audits: How often will technical teams run tests to check the AI output for drifting accuracy or emerging biases?

Step 6: Finalize, Notify, and Monitor

The final phase moves from internal documentation to formal external regulatory compliance.

- Action: Compile the final report, submit notifications, and schedule ongoing reviews.
- The Compliance Checklist:
 1. Draft the Report: Consolidate Steps 2 through 5 into a structured, unified compliance document.
 2. Leverage Existing DPIAs: To prevent redundant work, cross-reference and append any overlapping sections from your GDPR DPIAs.
 3. Notify the Authorities: Submit the finished FRIA results directly to your national market surveillance authority before the system goes live.
 4. Continuous Maintenance: Set a mandatory calendar reminder to review and update the FRIA if the AI software receives a major architectural update, or if its operational context changes.

BONUS: Sample Output of Steps 4, 5, and 6

Case Study Profile

- Company: EuroVantage Bank (Private Sector Entity)
- High-Risk AI System: "CreditPulse AI" (Onboarded from an external vendor)
- Intended Use Case: Automating the risk screening and creditworthiness tiering for retail mortgage applicants.

Step 4 Documentation: Mapping & Scoring Risks

The assessment team must explicitly link operational AI risks to specific sections of the EU Charter of Fundamental Rights.

Right 1: Non-Discrimination (Article 21)

- The Identified Risk: The vendor's AI model utilizes historical training data from the past 15 years. This historical data includes regional lending patterns that correlate with lower-income immigrant neighborhoods. The team identifies a high risk of indirect discrimination (proxy discrimination), where the AI might automatically penalize applicants based on zip codes or geographic data, disproportionately impacting minority groups.
- Risk Level: High (Severe impact, highly likely to occur without intervention).

Right 2: Consumer Protection & Fair Access (Article 38)

- The Identified Risk: The AI system uses deep-learning optimization to assign risk scores. The specific variables triggering a "rejection" are highly complex and non-linear. The bank risks accidentally creating a black-box scenario where a consumer is denied access to an essential financial service (a housing mortgage) without a clear, understandable business reason.
- Risk Level: Medium (High impact, moderate likelihood).

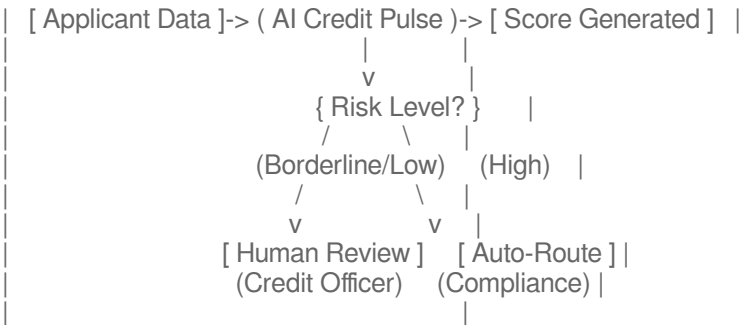
Right 3: Right to an Effective Remedy (Article 47)

- The Identified Risk: If the automated credit scoring tool instantly rejects an applicant, the standard frontend system simply displays a generic refusal message. This lacks a pathway for human review, effectively blocking the consumer's right to contest a negative legal or financial decision.
- Risk Level: High (Irreversible impact on the consumer's immediate housing options).

Step 5 Documentation: Oversight & Mitigation Protocols

Following the risk assessment, EuroVantage Bank designs and logs the following binding operational controls to mitigate the threats identified above.

EUROVANTAGE BANK: AI CONTROL GATEWAY



Control 1: Demographic Parity & Feature Stripping (Mitigates Art. 21 Risk)

- Technical Protocol: The bank's data engineering team strips all zip codes, addresses, nationality markers, and demographic metadata from the data payload before it reaches the AI endpoint.
- Organizational Protocol: The team institutes a quarterly algorithmic bias audit. They will run standard demographic parity tests across protected characteristics (using synthesized test sets) to ensure the model's approval rates stay uniform across different demographic segments.

Control 2: The Two-Tiered Human Oversight Model (Mitigates Art. 38 Risk)

- Technical Protocol: The bank configures the AI to never issue an automated *rejection*. The system is only permitted to issue automated *approvals* for top-tier credit scores.
- Operational Protocol: Any application flagged for rejection or a borderline score is automatically rerouted to a human Credit Review Officer. This officer must manually verify the financial indicators and make the final decision. The officer is equipped with a software dashboard that displays localized feature-importance weights (e.g., Debt-to-Income ratio) to help explain why the AI flagged the applicant.

Control 3: Mandated Explanations & Appeals Channel (Mitigates Art. 47 Risk)

- Client-Facing Protocol: If an application is ultimately denied after human review, the automated system is hardcoded to generate a specific, clear letters detailing the top three primary financial reasons for the denial (e.g., insufficient steady history, high debt ratio).
- Redress Protocol: The rejection notification includes a dedicated hyperlink allowing the applicant to open a formal appeal case directly with EuroVantage Bank's internal Compliance Desk within 14 business days.

Here is the formal compliance template designed for a corporate strategy guide. The bank's Chief Compliance Officer or AI Risk Lead would customize and submit this

document to their designated National Market Surveillance Authority to fulfill the legal reporting mandate of Article 27(2)

Step 6 Formal Notification: ARTICLE 27 FRIA COMPLETION

SUBMISSION TYPE: Prior Notification of High-Risk AI System Deployment
LEGAL BASE: Regulation (EU) 2024/1689 (EU AI Act), Article 27

1. IDENTIFICATION OF THE DEPLOYER

- Legal Entity Name: EuroVantage Bank SA
- Corporate Address: 45 Boulevard Royal, L-2449, Luxembourg
- Business Registration Number: LU-987654321
- Designated Compliance Contact: Elena Rostova, Chief Compliance Officer
- Contact Information: e.rostova@eurovantage.com | +352 22 33 44

2. SYSTEM IDENTIFICATION & PROVIDER DETAILS

- Commercial Name of System: CreditPulse AI (Version 4.2.1)
- EU AI Database Registration ID: EU-AID-2026-X89102 (*Note: Obtained from the vendor*)
- AI System Provider: FinTech Solutions Ltd. (Dublin, Ireland)
- High-Risk Category Trigger: Annex III, Point 5(b) — AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score.

3. OPERATIONAL CONTEXT & INTENDED PURPOSE

- Operational Scope: Assessing risk and determining credit tiering for retail consumers applying for housing mortgages within our digital portal.
- Intended Deployment Date: xx/xx/xxxx
- Target Population: Natural persons residing within the European Union applying for residential real estate financing.

4. SUMMARY OF FUNDAMENTAL RIGHTS IMPACT ASSESSMENT (FRIA)

Core Risks Identified (Article 27(1)(b))

- Charter Article 21 (Non-Discrimination): Potential for indirect geographic/proxy discrimination against minority groups due to historical localized lending patterns embedded in the vendor's base training model.
- Charter Article 38 (Consumer Protection): Risk of "black-box" decision outputs leading to arbitrary denials of mortgage financing without clear economic reasoning.

- Charter Article 47 (Right to an Effective Remedy): Risk of automated denial loops without a clear mechanism for human intervention, review, or appeal.

Implemented Mitigation & Oversight Protocols (Article 27(1)(d))

- Data Masking: Pre-processing pipelines automatically strip demographic markers, exact addresses, and proxy zip codes prior to model scoring.
- Human-in-the-Loop Safeguard: Automated "rejections" are technically blocked. The AI is structurally limited to issuing automated approvals for high-scoring applicants. All borderline or low scores are routed to a human Credit Review Officer for final, manual determination.
- Audit Frequency: Algorithmic bias audits and demographic parity checks will execute on a rolling quarterly cycle led by our internal Data Science Audit team.
- Redress Mechanism: All denied applicants receive a clear text summary explaining the primary financial factors behind the decision. Applicants are provided a dedicated channel to request a comprehensive manual review by our Compliance Desk within 14 business days.

5. CONCURRENT COMPLIANCE VERIFICATION

- GDPR Alignment: A comprehensive Data Protection Impact Assessment (DPIA) under Article 35 of the GDPR was finalized on August 4, 2026, and is appended to our internal file records.
- Provider Instructions: EuroVantage Bank verifies that all deployment protocols match the mandatory "Instructions for Use" provided by FinTech Scale Solutions Ltd.

6. LEGAL DECLARATION & SIGN-OFF

"By signing below, I certify that EuroVantage Bank SA has fully completed the Fundamental Rights Impact Assessment required under Article 27 of the EU AI Act. The complete, unredacted, detailed audit logs and risk matrices remain securely on file and are immediately available to the Market Surveillance Authority upon request."

Authorized Signature:

Elena Rostova

Chief Compliance Officer, EuroVantage Bank SA

Date of Notification: xx/xx/xxxx

Phase 4: Operational Infrastructure (Article 26)

Step 4.1: Technical Integration for Logging

Ensure your IT team can store the AI system's automatically generated logs for at least 6 months; 6 months is the legal floor, the regulations suggest that you must maintain logs for a period appropriate to the system's intended purpose. For industries like Banking and Insurance, logs of high risk AI are a mandated part of internal governance documentation, making the effective storage period for these logs 5 to 7 years.

- Check: If the vendor does not provide log export access, you cannot legally deploy the tool, unless you build your own system (important to remember that operational logs must be automatically generated.)

Step 4.2: Worker/Internal Notification

If the AI is used in the workplace (e.g., for performance reviews or hiring), formally notify workers and their representatives that AI will be used in decision-making.

BONUS: Training Module Guide

Company-Wide AI Literacy & Training Guide

Use this outline to build your internal training modules. Article 4 requires "sufficient AI literacy" taking into account the employee's technical knowledge and context [index:2.2.1].

Tier 1: General Workforce (Foundation Level)

Mandatory for all staff to ensure broad compliance and safety.

- **Module A:** What is AI?
 - Definition of AI vs. traditional software (it is probabilistic, not deterministic).
 - "The 70/30 Rule": AI handles 70% of the rote work; humans retain 30% for judgment and oversight [index:2.1.5].
- **Module B:** Permitted vs. Prohibited Use
 - The Red List: Never use AI for social scoring, biometric identification (unless authorized), or inferring emotions in the workplace.
 - Data Security: What data can never be put into a prompt (e.g., client names, trade secrets, PII).
- **Module C:** Transparency
 - Rule: "If you use AI to create content, you must say so." (Labeling requirements for emails, reports, and marketing assets).

Tier 2: High-Risk Operators (The "Human-in-the-Loop")

For HR managers, loan officers, and staff overseeing critical AI tools.

- **Module D:** Critical Thinking & Automation Bias
 - Automation Bias: Training staff to resist the tendency to automatically trust the machine.
 - Challenge Protocol: How and when to override the AI's decision (e.g., if a resume scanner rejects a qualified candidate).
- **Module E:** Input Data Hygiene
 - Verifying that the data fed into the system is relevant and representative (e.g., not using US-centric data for EU hiring decisions) [index:2.6.4].
- **Module F:** Interpretation of Outputs
 - Understanding confidence scores (e.g., "80% match" does not mean "True").

Tier 3: Executive & Compliance (Governance Level)

For Leadership, Legal, and IT Heads.

- **Module G: The Liability Shield**
 - Understanding that deployers are liable for the output of the AI they use, even if they didn't build it [index:2.3.3].
- **Module H: Incident Reporting**
 - Protocol for reporting "serious incidents" (death, harm to health, or breach of fundamental rights) to the national authority immediately.

Thank You



AXIOMATIC LAB REPORT

MAXIMIZING PRECISION & INNOVATION

Get your time back, visit axiomaticlab.com



E-Mail

axiomaticgroup@proton.me



Website

www.axiomaticlab.com